Parul® University
Vadodara, Gujarat

NAAC GRADE A++

Information and Communication Technology

Metasploit Frame work 303105324

Mr Bibungsarth Islary
Assistant Professor
CSE (Cyber Security)

Content

1. Multiple Communication Channels
2. Meterpreter Transports
3. Pivoting & Port Forwarding
4. Meterpreter Anti-Forensics
5. Desktop & Keystroke Sniffing
6. Meterpreter Resource Scripts
7. Timeout & Sleep Control
8. Windows Registry Interaction
9. Meterpreter API & Mixins
10. VNC Injection
11. Remote Desktop (RDP)
12. Meterpreter Detection & DFIR

MULTIPLE COMMUNICATION CHANNELS

Meterpreter Communication

Meterpreter requires a communication channel between the target and the Metasploit infrastructure.

Basic concept

Target

↓

Meterpreter

↓

Transport

↓

Network

↓

Handler

Communication channel determines

- How the session communicates
- Which protocol is used
- How the connection behaves
- How resilient the session is

Multiple Communication Channels

Multiple communication channels can be configured for a Meterpreter session.

Why?

- Increase connection reliability
- Handle network restrictions
- Provide transport flexibility
- Support authorized red-team scenarios
- Maintain communication if one path becomes unavailable

Key terminology

Primary Transport

Currently active communication mechanism.

Transport List

Available communication mechanisms associated with the session.

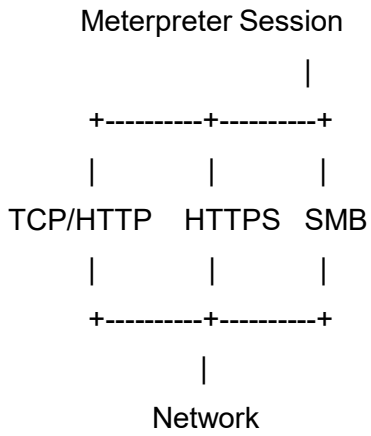
Transport Failover

Moving to another configured transport when the current one becomes unavailable.

The reference PPT specifically describes Meterpreter's `transports` functionality for managing these channels.

Communication Channel Architecture

Concept



Important idea

Different transports have different:

- Protocol characteristics
- Visibility
- Network requirements
- Performance
- Security implications

Transport Management

The reference PPT describes the `transports` functionality as the mechanism for managing Meterpreter communication channels.

Main operations

- View configured transports
- Add a transport
- Remove a transport
- Switch between transports
- Configure transport behavior

Conceptual workflow

```
Current Transport
↓
Failure / Change
↓
Alternative Transport
↓
Session Communication
```

For classroom practice, demonstrate this only within an isolated lab.

METERPRETER TRANSPORTS

What is a Meterpreter Transport?

A **transport** is the underlying communication mechanism through which the Meterpreter payload communicates with its handler.

Think of it as:

Payload = functionality

Transport = communication mechanism

Common transport families discussed in the reference material

- TCP
- HTTP
- HTTPS
- SMB

TCP Transport

TCP-based communication

Provides direct TCP communication between the session and handler.

Characteristics

- Low protocol overhead
- Fast communication
- Relatively simple
- Useful in controlled environments

Security perspective

Raw or unusual TCP connections can be identified through:

- Firewall logs
- NetFlow
- IDS/IPS
- EDR network telemetry

HTTP Transport

HTTP transport uses web communication characteristics.

Characteristics

- Uses HTTP communication
- Can operate through environments where web traffic is permitted
- Produces HTTP-related network telemetry

Security perspective

Defenders should examine:

- Destination
- URL patterns
- User-Agent
- Request frequency
- Process generating the traffic

HTTPS Transport

HTTPS adds TLS protection to the communication channel.

Advantages

- Encrypts network content
- Protects confidentiality of communication
- Resembles normal encrypted web traffic

Important security point

Encryption does not make communication invisible.

Defenders can still examine:

- Source/destination
- Timing
- Frequency
- TLS metadata
- Certificate information
- Process generating the traffic

SMB Transport

SMB is commonly used in Windows environments and can operate through named-pipe mechanisms.

Characteristics

- Useful in internal Windows environments
- Associated with SMB communication
- Can support internal session communication

Security relevance

SMB is important in:

- Lateral movement investigations
- Internal network monitoring
- Windows attack detection

Transport Comparison

Transport	Protocol	Main Characteristic	Security Visibility
TCP	TCP	Direct communication	High
HTTP	HTTP	Web-based communication	Moderate
HTTPS	HTTP + TLS	Encrypted communication	Content visibility reduced
SMB	SMB / Named Pipe	Windows internal communication	Important for internal monitoring

Dynamic Transport Switching

A major capability discussed in the reference PPT is **dynamic transport switching**.

Concept

Transport A

|

X

Unavailable

|

↓

Transport B

|

↓

Session continues

Security significance

This demonstrates why defenders should not rely on blocking only one:

- Port
- Protocol
- Destination

Instead, monitor the **endpoint + network behavior together**.

PIVOTING & PORT FORWARDING

Pivoting Concept

Pivoting allows an already-accessible system to provide a path toward another network or system.

Concept

Tester
|
↓
Compromised Host
|
↓
Internal Network
|
+---- Host A
+---- Host B
+---- Host C

Why pivot?

The tester may not have direct connectivity to internal systems.

Pivoting vs Multiple Transports

These concepts should not be confused.

Multiple transports

Concerned with:

How the Meterpreter session communicates.

Pivoting

Concerned with:

How traffic reaches another network/system through an existing foothold.

Simple distinction

Transport = communication path

Pivot = network reachability

The reference PPT explicitly distinguishes the use of pivoting to reach internal network segments from simply creating another Internet communication channel.

Port Forwarding

Port forwarding maps traffic from one location to another through an established communication path.

Concept

Local Machine

|

Local Port

|

↓

Meterpreter Tunnel

|

↓

Internal Target

|

Target Service

Security relevance

Port forwarding can make an otherwise inaccessible internal service reachable through an existing session.

Detection

Monitor:

- Unexpected listening ports
- Unusual local connections
- Internal service access
- Network path changes

METERPRETER ANTI-FORENSICS

Meterpreter Anti-Forensics

Meterpreter is designed for post-exploitation operations and can perform many operations in memory.

Anti-forensic concept

Attempts to:

- Reduce disk artifacts
- Minimize evidence
- Complicate investigation
- Avoid unnecessary file creation
- Reduce operational footprint

Meterpreter Forensic Trail

Even when activity occurs primarily in memory, investigators can find evidence.

Possible evidence

- Process injection
- Suspicious memory regions
- Network connections
- Process behavior
- Authentication events
- Event logs
- EDR telemetry

Important principle

Fileless ≠ invisible

Process Injection

Process injection involves placing or executing code within another process.

Concept

Process A
|
| Injection
↓
Process B
|
↓
Injected Code

DFIR relevance

Investigators can examine:

- Process relationships
- Memory regions
- Remote-thread behavior
- Cross-process access
- Unusual loaded modules

Anti-Forensics and Event Logs

Attackers may attempt to clear or alter logs.

But log clearing itself can become evidence.

For example, Windows Security Event Log clearing can generate:

Event ID 1102

SOC perspective

Instead of hiding the event:

`Log Cleared`

can become:

`High-Priority Security Alert`

The reference PPT specifically highlights Event ID 1102 as an important detection signal.

OPSEC in Authorized Testing

OPSEC = Operational Security

During professional assessments, testers should minimize unnecessary impact and activity.

Good practice

- Run only required tests
- Follow rules of engagement
- Avoid unnecessary modifications
- Document actions
- Preserve evidence when required
- Clean up authorized changes

Important

A professional penetration test is **not a competition to leave zero evidence**.

Anti-Forensics Detection

Sysmon

Useful events include:

- Process creation
- Process access
- Network connections

Memory Forensics

Can help identify:

- Injected code
- Suspicious memory regions
- Unusual processes

SIEM

Can correlate:

- Log clearing
- Process activity
- Network connections
- User accounts

DESKTOP & KEYSTROKE SNIFFING

Desktop Interaction

Meterpreter provides functionality for interacting with a graphical desktop.

Examples discussed in the reference PPT

- Screenshot capture
- Real-time screen sharing
- User-interface control

Security impact

Desktop access can expose:

- Documents
- Applications
- Credentials
- Sensitive information
- User activity

get-desktop Concept

The **get-desktop** functionality relates to obtaining information about the desktop context associated with the Meterpreter session.

Important concepts

- Desktop/session context
- Logged-in user
- GUI environment
- Interactive session

Why it matters

The same technical foothold can have very different capabilities depending on:

- User context
- Session type
- Privileges
- Desktop availability

User Interface Control

Meterpreter's UI-related functionality can interact with keyboard/mouse input in supported environments.

Security implications

Potentially allows an attacker to:

- Observe user activity
- Interfere with interaction
- Demonstrate impact of GUI-level compromise

Defensive perspective

Unexpected GUI-control behavior should be investigated in combination with:

- Process activity
- User context
- EDR telemetry
- Network connections

Keystroke Sniffing

Keystroke sniffing / keylogging records keyboard input.

Potentially exposed information

- Usernames
- Passwords
- Commands
- Messages
- Confidential data

Security impact

It attacks the **credential-use process**, rather than merely attacking stored credentials.

Keyscan Workflow

The reference PPT identifies three major stages:

Start

Begin collecting keyboard input.

Dump

Retrieve collected keystrokes.

Stop

Terminate collection.

Conceptually:

Start
↓
Capture Input
↓
Collect
↓
Retrieve
↓
Stop

Keylogging Detection

Possible detection mechanisms

API monitoring

- Suspicious input-hooking behavior

Behavioral detection

- Unexpected input capture
- Frequent screen capture

Memory analysis

- Suspicious keylogging components in process memory

Defensive controls

- EDR
- Application control
- Least privilege
- Endpoint integrity
- Credential protection

The reference PPT specifically discusses API hooking, behavioral analysis and memory scanning.

RESOURCE SCRIPTS

Meterpreter Resource Scripts

A **resource script** is a text file containing a sequence of Metasploit/Meterpreter commands.

Purpose

- Automate repetitive operations
- Standardize testing
- Improve consistency
- Reproduce lab workflows

Resource Script Structure

Conceptually:

Resource File

|

+--- Command 1

+--- Command 2

+--- Command 3

+--- Command 4

|

↓

Meterpreter Session

Typical educational workflow

- System information
- User/context information
- Network information
- Security checks
- Evidence collection

Resource Script Execution

The reference PPT describes using the `resource` mechanism to execute a predefined script in an active session.

Advantages

- Repeatability
- Speed
- Consistency
- Reduced manual error

Important security concern

Automation can also scale malicious behavior.

Therefore:

Detect sequences of behavior, not only individual commands.

AutoRunScript

The reference PPT also discusses **AutoRunScript**.

Concept

A predefined script can be configured to execute automatically after a session becomes available.

Security significance

Automation can:

- Reduce manual interaction
- Immediately perform predefined actions
- Standardize post-session workflows

Detection

Monitor unusual automated sequences immediately following session establishment.

TIMEOUT & SLEEP CONTROL

Timeout Control

Timeout control determines how a session handles communication delays and connection-related conditions.

Main objectives

- Connection reliability
- Session stability
- Handling network delays
- Reconnection behavior

Sleep Control

Sleep control determines periods during which the session remains inactive between communication/activity cycles.

Concept

Active

↓

Sleep

↓

Communication

↓

Sleep

↓

Communication

Security relevance

Communication intervals can influence:

- Network noise
- Responsiveness
- Detectability
- Traffic patterns

Timeout vs Sleep Control

Feature	Timeout	Sleep
Main purpose	Connection/session handling	Activity timing
Concern	Reliability	Communication frequency
Effect	Wait/failure behavior	Inactivity interval
Detection	Connection anomalies	Periodic traffic patterns

WINDOWS REGISTRY

Windows Registry

The Windows Registry stores configuration information used by Windows and applications.

Major root keys

- HKLM
- HKCU
- HKCR
- HKU
- HKCC

Information may include

- Software configuration
- User settings
- System settings
- Startup configuration
- Security-related configuration

Meterpreter Registry Interaction

Meterpreter provides registry interaction capabilities.

Common operations

- Enumerate registry keys
- Enumerate values
- Query values
- Modify values where permissions permit

Registry Permissions

Registry access depends on the security context of the session.

Important factors

- Current user
- Administrator privileges
- SYSTEM privileges
- Registry key permissions
- Architecture

Important concept

Access ≠ unrestricted access

The compromised session still operates within an applicable security context.

Registry Redirection

On 64-bit Windows systems, 32-bit applications can encounter **registry redirection**.

Concept

32-bit Application

↓

Registry Access

↓

Windows Registry View

The location observed by a process may differ depending on:

- Operating-system architecture
- Process architecture
- Registry redirection

Registry as a Persistence Artifact

Certain registry locations can be associated with programs that execute during startup or user logon.

DFIR importance

Investigators can examine:

- Registry modifications
- Startup-related entries
- Modification timestamps where available
- Associated executable paths
- User context

Security lesson

Registry modification can be both:

An attack technique

and

A forensic artifact

METERPRETER API & MIXINS

Meterpreter API

The Meterpreter API provides communication between the Metasploit client and Meterpreter server components.

Architecture

Metasploit Client

|

| Requests

↓

Meterpreter Server

|

↓

Target System

Meterpreter Server and Client

Client

Runs with the Metasploit framework.

Responsible for:

- User interaction
- Sending requests
- Receiving responses
- Managing sessions

Server

Runs within the target environment.

Responsible for:

- Receiving requests
- Executing functionality
- Returning results

Important

The terms **client/server here describe Meterpreter architecture**, not necessarily the direction of the network connection.

TLV Protocol

Meterpreter uses a structured **TLV model**:

TLV

T = Type

L = Length

V = Value

Concept

Type | Length | Value

This allows information to be structured and exchanged between components.

Meterpreter Extensions

Meterpreter's core is designed to be modular.

Concept

Meterpreter Core

|

+--- Extension A

+--- Extension B

+--- Extension C

|

↓

Additional Capabilities

Benefits

- Modular functionality
- Reduced core complexity
- Extensibility
- Reusable components

Meterpreter Mixins

Mixins belong primarily to the Metasploit Framework's Ruby development architecture.

Purpose

They provide reusable methods to module developers.

Benefits

- Code reuse
- Standardized functionality
- Abstraction
- Cross-session handling

Post-Exploitation Mixins

The reference PPT identifies examples such as:

`Msf::Post::Common`

Provides common post-exploitation utilities.

`Msf::Post::Windows::Priv`

Provides standardized privilege-related functionality.

`Msf::Post::File`

Abstracts file-system operations.

Key idea

Mixins allow developers to write modules against **common abstractions instead of rebuilding platform-specific functionality repeatedly**.

VNC INJECTION

What is VNC Injection?

VNC Injection is a post-exploitation technique in which a VNC server component is introduced into a running target process to provide graphical interaction.

Concept

Meterpreter Session

↓

Target Process

↓

VNC Component

↓

Graphical Desktop

VNC Injection and Process Injection

VNC injection may involve:

- Cross-process memory operations
- Code loading
- Remote thread execution
- Desktop/graphics interaction

Security perspective

This creates detectable behavioral indicators.

Potential signals include:

- Executable memory allocation
- Cross-process memory writes
- Remote thread creation
- Unexpected network behavior

VNC Detection

Endpoint

Look for:

- Cross-process injection
- Suspicious memory allocation
- Unexpected threads
- Unusual process behavior

Network

Look for:

- Unexpected VNC-related connections
- New listening behavior
- Unusual screen-data traffic

Memory

Look for:

- Injected threads
- Unbacked executable memory
- Suspicious modules

REMOTE DESKTOP / RDP

Remote Desktop Protocol

RDP provides graphical remote access to Windows systems.

Architecture

Remote Client

|

↓

Network

|

↓

RDP Service

|

↓

Windows Desktop

Default RDP service port

TCP 3389

Enabling Remote Desktop

In an authorized assessment, RDP enablement demonstrates how an existing foothold can be converted into remote graphical access.

The reference PPT describes three important areas:

- Registry configuration
- Windows Firewall configuration
- User/account permissions

RDP Registry Configuration

Windows maintains configuration related to whether Remote Desktop connections are permitted.

Security-relevant location

Terminal Server configuration

DFIR significance

A change that enables RDP can become an investigation artifact.

Monitor

- Registry modifications
- Configuration changes
- Process responsible for modification

RDP Firewall Configuration

Enabling RDP may require appropriate firewall configuration.

Security consequence

A firewall rule permitting RDP increases the reachable attack surface.

Defender should monitor

- New firewall rules
- Changes to existing rules
- TCP 3389 exposure
- Source networks allowed to connect

Network Level Authentication

NLA = Network Level Authentication

NLA requires authentication before a full Remote Desktop session is established.

Security benefit

It helps reduce exposure to certain pre-authentication attack scenarios.

Recommendation

Keep NLA enabled where appropriate and supported.

RDP Detection

SOC monitoring

Monitor:

- Successful RDP logins
- Failed authentication attempts
- Source IP addresses
- Privileged accounts
- Unusual login times
- New RDP configuration

Correlation

Registry Change

+

Firewall Change

+

RDP Login

+

Unusual Source

↓

High-Priority Investigation

Meterpreter Detection Strategy

There is no single "Meterpreter signature" that guarantees detection.

Use multiple telemetry sources

Endpoint

- Process
- Memory
- DLL/module behavior
- Process injection

Network

- Connections
- Periodicity
- Destinations
- Protocol behavior

Authentication

- User
- Source
- Time
- Privilege

Configuration

- Registry
- Firewall
- Services

SOC Correlation

Example

Suspicious Process

+

Unexpected Network Connection

+

Registry Modification

+

Unusual Login

↓

Potential Post-Exploitation Activity

Important principle

Correlation increases confidence.

A single unusual event may be legitimate.

Several related events occurring together are much more significant.

DFIR Investigation

When investigating suspected Meterpreter/post-exploitation activity:

1. Identify initial access

How did the session originate?

2. Identify execution

Which process executed?

3. Identify communication

Where did the endpoint communicate?

4. Identify privileges

Which user/security context was involved?

5. Identify actions

What happened after session establishment?

6. Build timeline

Correlate all evidence sources.

Evidence Sources

Endpoint

- Windows Event Logs
- Sysmon
- EDR
- Process telemetry
- Memory

Network

- Firewall logs
- IDS/IPS
- NetFlow
- Packet captures
- DNS logs

System

- Registry
- File system
- Services
- Authentication records

Tools

- Wireshark
- Sysmon
- Volatility
- Wazuh
- Splunk
- ELK

Case Study

Scenario

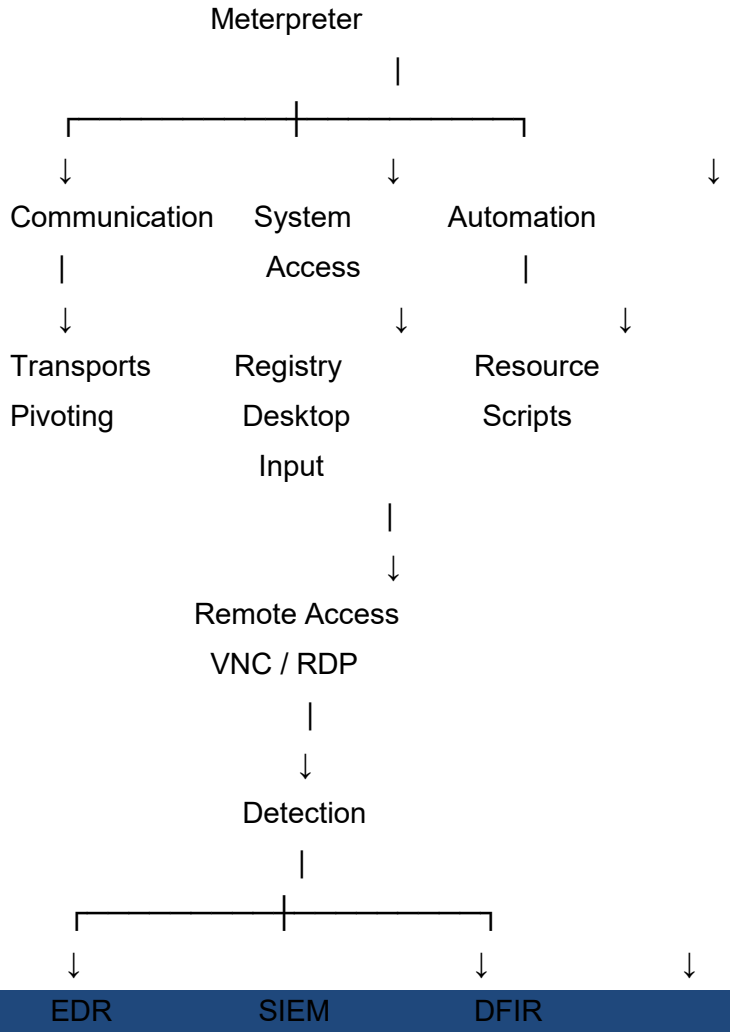
A Windows workstation generates:

1. Unusual process execution
2. Outbound network connection
3. Registry modification
4. Unexpected RDP configuration change
5. Remote login

Student questions

- Which event occurred first?
- What is the likely attack sequence?
- Which events are strong indicators?
- What telemetry confirms the activity?
- What security control could have stopped it?

Complete Meterpreter-2 Concept



Parul® University | NAAC GRADE A++

https://paruluniversity.ac.in/

